Relatório dinâmico de inspeção de segurança

Inspeção estática preliminar. Este PDF é regenerado a cada execução e substitui o relatório no caminho de saída escolhido.

1. Status e identificação

Status geral: Revisão humana necessária; este inspetor não aprova nem reprova o projeto

Projeto: LF-Engineering-System

Raiz: caminho absoluto omitido; evidências usam caminhos relativos

Gerado em: 2026-11-01T21:12:12-03:00

Arquivos regulares inventariados: 335

Arquivos-fonte por extensão: .ps1: 3, .py: 2, .sh: 5

2. Escopo e método

- O inspetor lê arquivos locais e produz evidências de inventário e padrões de alta confiança; não executa código, testes do projeto ou comandos dentro do projeto.
- Não usa rede, não instala dependências, não altera permissões e não remove arquivos. O PDF de saída é sobrescrito em cada execução.
- Diretórios comuns de dependências/build e links simbólicos não são percorridos. Arquivos binários são ignorados; arquivos não legíveis são contados como não verificados.
- Segredos detectados são reportados somente por tipo, caminho e linha; o valor correspondente nunca é copiado para o relatório.
- A varredura não examina histórico Git, validade de credenciais, fluxo de dados, autorização real, execução dinâmica, dependências vulneráveis ou comportamento em produção.

Arquivos de texto lidos: 335

Arquivos binários ignorados: 0

Links simbólicos ignorados: 0

Arquivos/diretórios não legíveis: 0

Arquivo de saída excluído do scan: 1

Diretórios ignorados: .git: 1

3. Perfil observado do projeto

Manifestos: Nenhum indicador encontrado.

Documentação: CHANGELOG.md, CONTRIBUTING.md, OVERVIEW.md, README.md, README.pt-BR.md, ROADMAP.md, SECURITY.md, TESTING.md, .opencode/README.md, PROJECT_TEMPLATE/README.md, PROJECT_TEMPLATE/docs/ADR.md, PROJECT_TEMPLATE/docs/ARCHITECTURE.md e mais 88

Configuração/CI/deploy: .github/workflows/release.yml, .github/workflows/validate.yml

Indicadores de interface web: Nenhum indicador encontrado.

Indicadores de backend: Nenhum indicador encontrado.

Indicadores de workflow de IA: AGENTS.md, .opencode/.gitignore, .opencode/README.md, .opencode/opencode.jsonc, .opencode/orchestrator.md, .opencode/agents/code-reviewer.md, .opencode/agents/design-system-analyst.md, .opencode/agents/documentation.md, .opencode/agents/engineering-knowledge-extractor.md, .opencode/agents/engineering-manager.md, .opencode/agents/orchestrator.md, .opencode/agents/product-owner.md e mais 11

Arquivos candidatos a estado local: 0

4. Matriz de aplicabilidade de segurança

A aplicabilidade é inferida por indicadores de nomes/extensões; um resultado heurístico não substitui a leitura do projeto.

Injeção SQL/comandos: Não verificado

> Foram detectados indicadores de código-fonte; a análise automatizada não valida o fluxo de dados.

XSS/HTML: Não aplicável (heurístico)

> Nenhum indicador de interface web/HTML foi detectado no inventário; isso não prova ausência da superfície.

Autenticação/autorização/IDOR: Não aplicável (heurístico)

Nenhum indicador de rotas/handlers de backend foi detectado no inventário; isso não prova ausência da superfície.

Segredos/dados sensíveis: Não verificado

Nenhuma assinatura de alta confiança encontrada; a busca é limitada e não prova ausência de segredos.

Deploy/configuração: Não verificado

Foram detectados indicadores de manifestos ou configuração/deploy; a análise automatizada não valida o fluxo de dados.

Workflows de IA/uso de ferramentas: Não verificado

Foram detectados indicadores de instruções/adapters de workflow de IA; a análise automatizada não valida o fluxo de dados.

Efeitos externos: Não verificado

Foram detectados indicadores de código ou automação; a análise automatizada não valida o fluxo de dados.

5. Categorias de QA-Security

Performance: Não verificado

O inventário pode detectar arquivos web, mas não mede rotas, build de produção, mobile/desktop, Core Web Vitals ou orçamento.

Observabilidade: Não verificado

Logs e configurações podem ser inventariados; qualidade, cobertura e exposição de dados exigem revisão.

Código/manutenibilidade: Não verificado

A contagem de extensões não avalia arquitetura, correção, complexidade ou requisitos.

Documentação: Indicadores inventariados

CHANGELOG.md, CONTRIBUTING.md, OVERVIEW.md, README.md, README.pt-BR.md, ROADMAP.md, SECURITY.md, TESTING.md, .opencode/README.md, PROJECT_TEMPLATE/README.md, PROJECT_TEMPLATE/docs/ADR.md, PROJECT_TEMPLATE/docs/ARCHITECTURE.md e mais 88

Acessibilidade: Não verificado

Testes de teclado, foco, contraste, zoom, reflow e tecnologia assistiva não são executados.

Boas práticas: Não verificado

O inspetor não declara conformidade com SOLID, DRY, KISS, YAGNI ou Clean Architecture.

6. Problemas encontrados

Nenhum padrão de alta confiança ou problema de permissão foi detectado pelas verificações implementadas. Isso não significa ausência de vulnerabilidades; várias categorias permanecem não verificadas.

7. Limitações e checklist final

- [ ] QA-Security revisou o escopo, as categorias e os indicadores de aplicabilidade.
- [ ] Cada achado potencial foi confirmado ou rejeitado com evidência do projeto.
- [ ] Segredos, permissões e estado local foram revisados sem copiar valores sensíveis para o relatório.
- [ ] Fluxos de autenticação/autorização, efeitos externos e workflows de IA foram testados quando aplicáveis.
- [ ] Interfaces foram validadas manualmente e com evidências mobile/desktop quando aplicável.
- [ ] Nenhum arquivo foi removido ou alterado automaticamente pelo inspetor.

Conclusão: este relatório é uma coleta dinâmica e limitada de evidências locais. A decisão técnica final pertence ao QA-Security e ao responsável pelo projeto.